



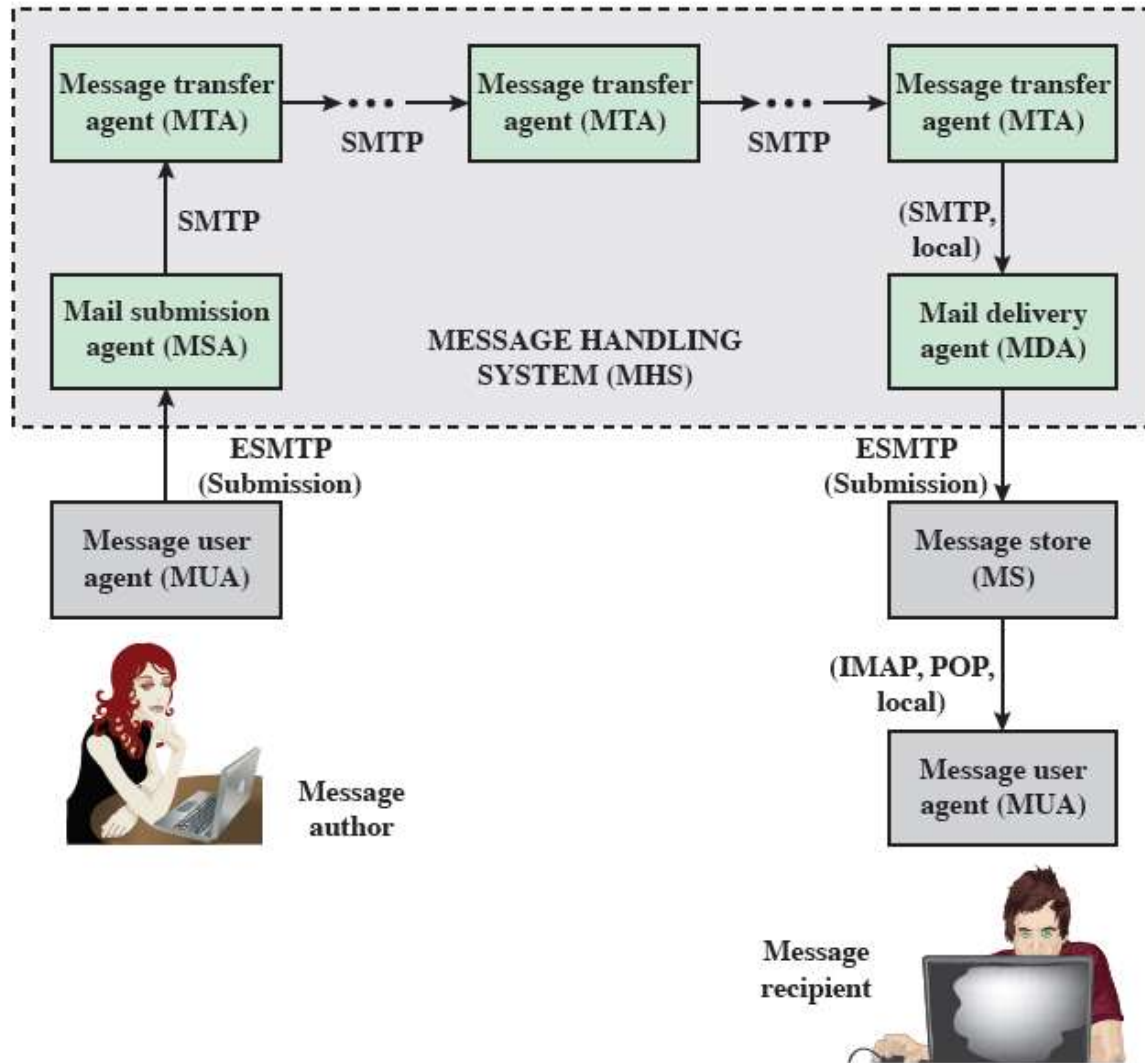
5CM512 Communication and Security Protocols

Week 9: Electronic Email Security

Class discussion

- Why should we bother with Email Security?

Internet mail architecture

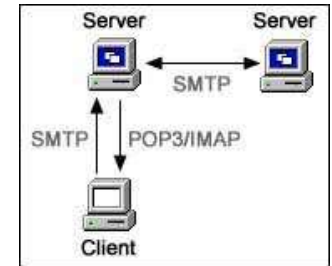


- Defined in RFC 5598
- E-mail components:
 - User World:
 - Message User Agents (MUA)
 - Transfer World
 - Message Handling Service (MHS)
 - Message Transfer Agents (MTA)

E-Mail Protocols

SMTP

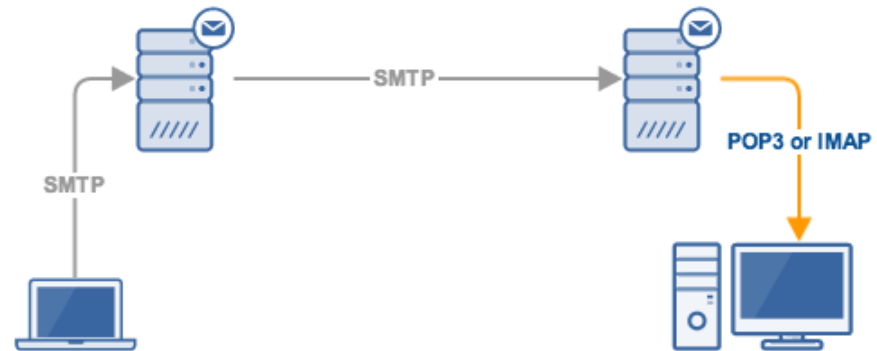
- Simple Mail Transfer Protocol (SMTP)
 - Encapsulates an e-mail message in an envelope
 - relay the encapsulated messages from source to destination through multiple MTAs
- Text-based client-server protocol
 - The client (e-mail sender) contacts the server (next-hop recipient)
 - It issues a set of commands to tell the server about the message to be sent
 - Then sending the message itself
- The majority of these commands are ASCII text messages sent by the client and a resulting return code returned by the server



Example SMTP Transaction Scenario

```
S: .220.foo.com.Simple.Mail.Transfer.Service.Ready␣␣
C: .HELO.bar.com␣␣
S: .250.OK␣␣
C: .MAIL.FROM:<Smith@bar.com>␣␣
S: .250.OK␣␣
C: .RCPT.TO:<Jones@foo.com>␣␣
S: .250.OK␣␣
C: .RCPT.TO:<Green@foo.com>␣␣
S: .550.No.such.user.here␣␣
C: .RCPT.TO:<Brown@foo.com>␣␣
S: .250.OK␣␣
C: .DATA␣␣
S: .354.Start.mail.input;.end.with.<CRLF>.<CRLF>␣␣
C: .Blah.blah.blah...␣␣
C: ....etc..etc..etc.␣␣
C: .<CRLF><CRLF>␣␣
S: .250.OK␣␣
C: .QUIT␣␣
S: .221.foo.com.Service.closing.transmission.channel␣␣
```

Mail access protocols



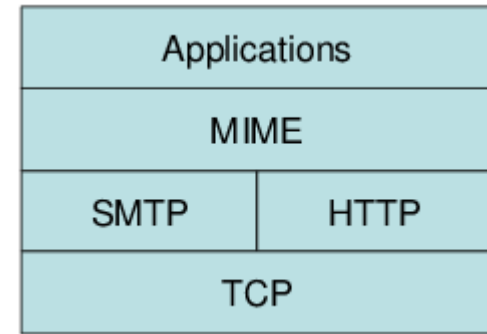
Post Office Protocol (POP3)

- Allows an e-mail client (user agent) to download an e-mail from an e-mail server (MTA)
- POP3 user agents connect via TCP to the server (usually port 110)

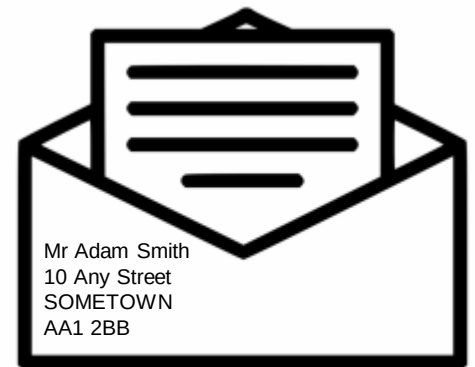
Internet Mail Access Protocol (IMAP)

- Enables an e-mail client to access mail on an e-mail server
- Uses TCP, with server TCP port 143
- Is more complex than POP3
- Provides stronger authentication than POP3 and provides other functions not supported by POP3

E-mail formats



- Multipurpose Internet Mail Extensions (MIME)
 - Defines a format for text messages
 - Standard for Internet-based text mail messages
 - Messages : envelope + contents
 - Envelope
 - information is needed to accomplish transmission and delivery
 - Contents
 - compose the object to be delivered to the recipient



Header fields defined in mime

- MIME-Version
 - This field indicates that the message conforms to RFCs 2045 and 2046
- Content-Type
 - Describes the data contained in the body with sufficient detail that the receiving user agent can pick an appropriate agent or mechanism to represent the data to the user or otherwise deal with the data in an appropriate manner
- Content-Transfer-Encoding
 - Indicates the type of transformation that has been used to represent the body of the message in a way that is acceptable for mail transport
- Content-ID
 - Used to identify MIME entities uniquely in multiple contexts
- Content-Description
 - A text description of the object with the body

MIME Content Types

Type	Subtype	Description
Text	Plain	Unformatted text; may be ASCII or ISO 8859.
	Enriched	Provides greater format flexibility.
Multipart	Mixed	The different parts are independent but are to be transmitted together. They should be presented to the receiver in the order that they appear in the mail message.
	Parallel	Differs from Mixed only in that no order is defined for delivering the parts to the receiver.
	Alternative	The different parts are alternative versions of the same information. They are ordered in increasing faithfulness to the original, and the recipient's mail system should display the "best" version to the user.
	Digest	Similar to Mixed, but the default type/subtype of each part is message/rfc822.
Message	rfc822	The body is itself an encapsulated message that conforms to RFC 822.
	Partial	Used to allow fragmentation of large mail items, in a way that is transparent to the recipient.
	External-body	Contains a pointer to an object that exists elsewhere.
Image	jpeg	The image is in JPEG format, JFIF encoding.
	gif	The image is in GIF format.
Video	mpeg	MPEG format.
Audio	Basic	Single-channel 8-bit ISDN μ -law encoding at a sample rate of 8 kHz.
Application	PostScript	Adobe Postscript format.
	octet-stream	General binary data consisting of 8-bit bytes.

MIME Transfer Encodings

7 bit	The data are all represented by short lines of ASCII characters.
8 bit	The lines are short, but there may be non-ASCII characters (octets with the high-order bit set).
binary	Not only may non-ASCII characters be present but the lines are not necessarily short enough for SMTP transport.
quoted-printable	Encodes the data in such a way that if the data being encoded are mostly ASCII text, the encoded form of the data remains largely recognizable by humans.
base64	Encodes data by mapping 6-bit blocks of input to 8-bit blocks of output, all of which are printable ASCII characters.
x-token	A named nonstandard encoding.

Example MIME Message Structure

MIME-Version: 1.0
From: Nathaniel Borenstein <nsb@bellcore.com>
To: Ned Freed <ned@innosoft.com>
Subject: A multipart example
Content-Type: multipart/mixed;
boundary=unique-boundary-1

This is the preamble area of a multipart message. Mail readers that understand multipart format should ignore this preamble. If you are reading this text, you might want to consider changing to a mail reader that understands how to properly display multipart messages.

--unique-boundary-1

...Some text appears here...

[Note that the preceding blank line means no header fields were given and this is text, with charset US ASCII. It could have been done with explicit typing as in the next part.]

--unique-boundary-1

Content-type: text/plain; charset=US-ASCII

This could have been part of the previous part, but illustrates explicit versus implicit typing of body parts.

--unique-boundary-1

Content-Type: multipart/parallel; boundary=unique-boundary-2

--unique-boundary-2

Content-Type: audio/basic

Content-Transfer-Encoding: base64

... base64-encoded 8000 Hz single-channel mu-law-format audio data goes here....

--unique-boundary-2

Content-Type: image/jpeg

Content-Transfer-Encoding: base64

... base64-encoded image data goes here....

--unique-boundary-2--

--unique-boundary-1

Content-type: text/enriched

This is <bold><italic>richtext.</italic></bold> <smaller>as defined in RFC 1896</smaller>

Isn't it <bigger><bigger>cool?</bigger></bigger>

--unique-boundary-1

Content-Type: message/rfc822

From: (mailbox in US-ASCII)

To: (address in US-ASCII)

Subject: (subject in US-ASCII)

Content-Type: Text/plain; charset=ISO-8859-1

Content-Transfer-Encoding: Quoted-printable

... Additional text in ISO-8859-1 goes here ...

--unique-boundary-1--

CLASS discussion

- Discuss the possible threats posed by E-mails and E-mail system.

E-mail threats

E-mail security threats can be classified as:

Authenticity-related threats

- Could result in unauthorized access to an enterprise's e-mail system

Integrity-related threats

- Could result in unauthorized modification of e-mail content

Confidentiality-related threats

- Could result in unauthorized disclosure of sensitive information

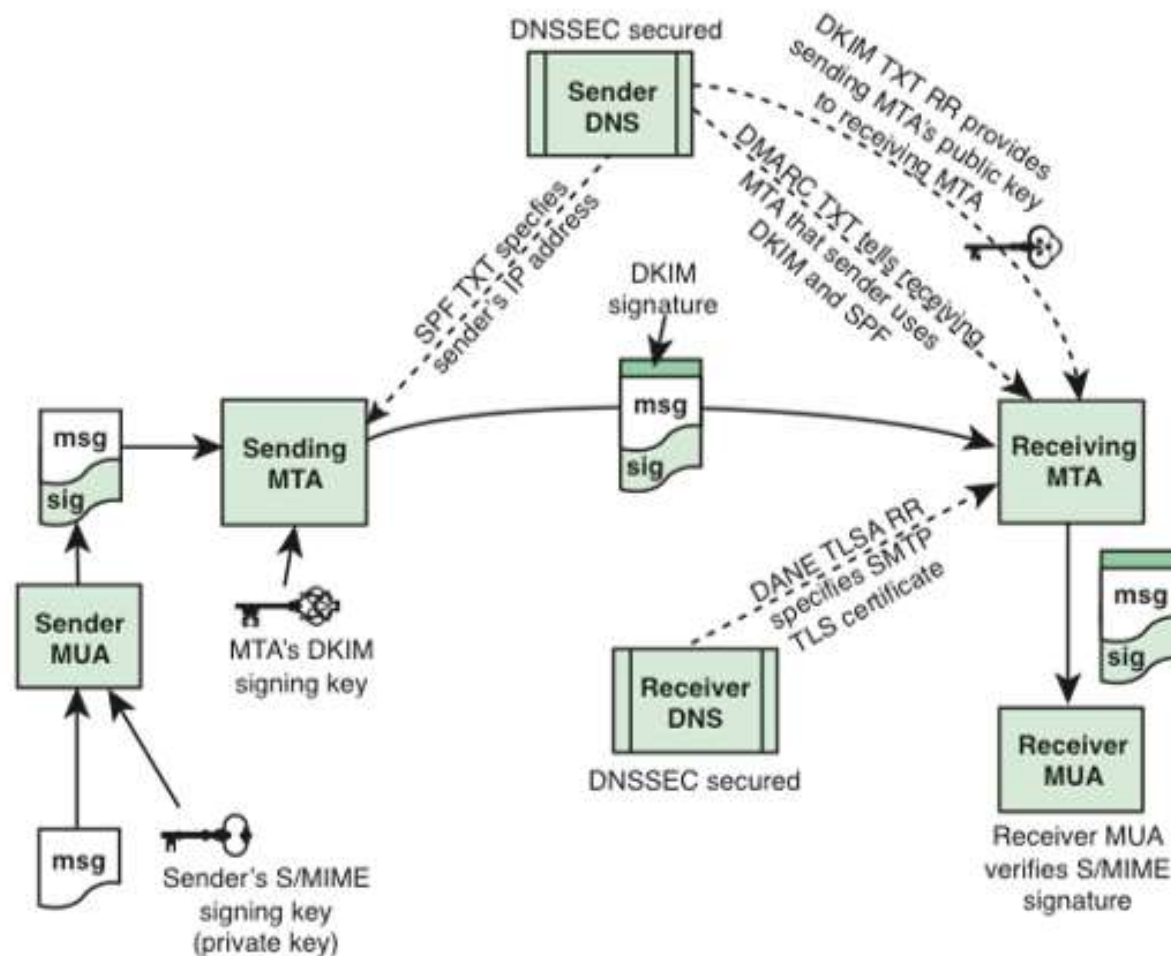
Availability-related threats

- Could prevent end users from being able to send or receive e-mail

Email Threats and Mitigations

Threat	Impact on Purported Sender	Impact on Receiver	Mitigation
E-mail sent by unauthorized MTA in enterprise (e.g., malware botnet)	Loss of reputation, valid e-mail from enterprise may be blocked as possible spam/phishing attack.	UBE and/or e-mail containing malicious links may be delivered into user inboxes.	Deployment of domain-based authentication techniques. Use of digital signatures over e-mail.
E-mail message sent using spoofed or unregistered sending domain	Loss of reputation, valid e-mail from enterprise may be blocked as possible spam/phishing attack.	UBE and/or e-mail containing malicious links may be delivered into user inboxes.	Deployment of domain-based authentication techniques. Use of digital signatures over e-mail.
E-mail message sent using forged sending address or e-mail address (i.e., phishing, spear phishing)	Loss of reputation, valid e-mail from enterprise may be blocked as possible spam/phishing attack.	UBE and/or e-mail containing malicious links may be delivered. Users may inadvertently divulge sensitive information or PII.	Deployment of domain-based authentication techniques. Use of digital signatures over e-mail.
E-mail modified in transit	Leak of sensitive information or PII.	Leak of sensitive information, altered message may contain malicious information.	Use of TLS to encrypt e-mail transfer between servers. Use of end-to-end e-mail encryption.
Disclosure of sensitive information (e.g., PII) via monitoring and capturing of e-mail traffic	Leak of sensitive information or PII.	Leak of sensitive information, altered message may contain malicious information.	Use of TLS to encrypt e-mail transfer between servers. Use of end-to-end e-mail encryption.
Unsolicited Bulk E-mail (UBE) (i.e., spam)	None, unless purported sender is spoofed.	UBE and/or e-mail containing malicious links may be delivered into user inboxes.	Techniques to address UBE.
DoS/DDoS attack against an enterprises' e-mail servers	Inability to send e-mail.	Inability to receive e-mail.	Multiple mail servers, use of cloud-based e-mail providers.

The Interrelationship of DNSSEC, SPF, DKIM, DMARC, DANE, and S/MIME for Assuring Message Authenticity and Integrity



DANE = DNS-based Authentication of Named Entities

DKIM = DomainKeys Identified Mail

DMARC = Domain-based Message Authentication, Reporting, and Conformance

DNSSEC = Domain Name System Security Extensions

SPF = Sender Policy Framework

S/MIME = Secure Multi-Purpose Internet Mail Extensions

TLSA RR = Transport Layer Security Authentication Resource Record

S/MIME

Secure/Multipurpose
Internet Mail
Extension

S/MIME is a
complex capability
that is defined in a
number of documents

Is a security
enhancement to the
MIME Internet e-mail
format standard based
on technology from
RSA Data Security

Class discussion

- What functions do we need in S/MIME?

Summary of S/MIME Services

Function	Typical Algorithm	Typical Action
Digital signature	RSA/SHA-256	A hash code of a message is created using SHA-256. This message digest is encrypted using SHA-256 with the sender's private key and included with the message.
Message encryption	AES-128 with CBC	A message is encrypted using AES-128 with CBC with a one-time session key generated by the sender. The session key is encrypted using RSA with the recipient's public key and included with the message.
Compression	unspecified	A message may be compressed for storage or transmission.
E-mail compatibility	Radix-64 conversion	To provide transparency for e-mail applications, an encrypted message may be converted to an ASCII string using radix-64 conversion.

AUTHENTICATION



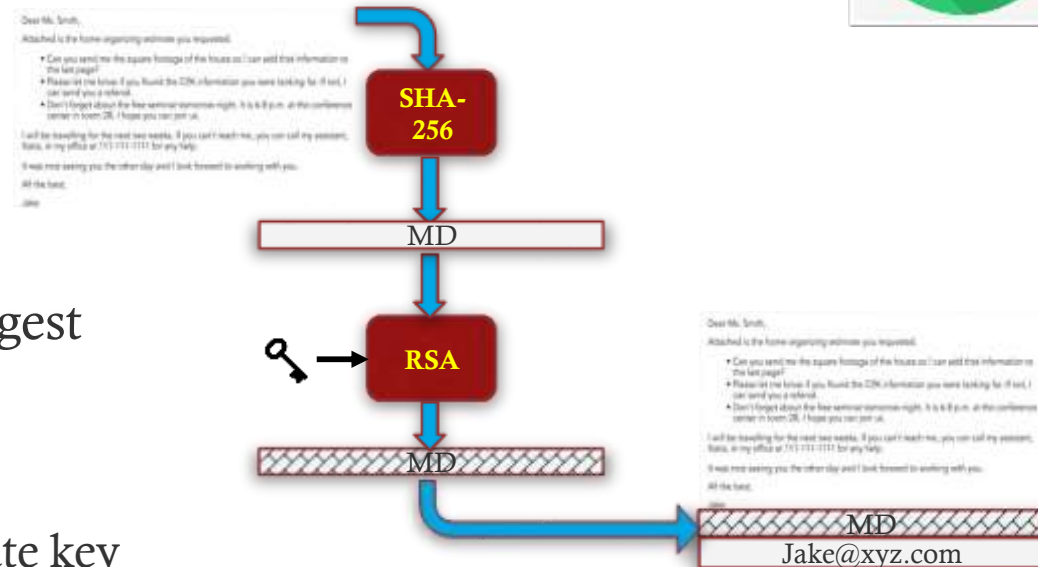
- What service can be used for authentication?

- Digital Signature

- **RSA with SHA-256**

- **Sender :**

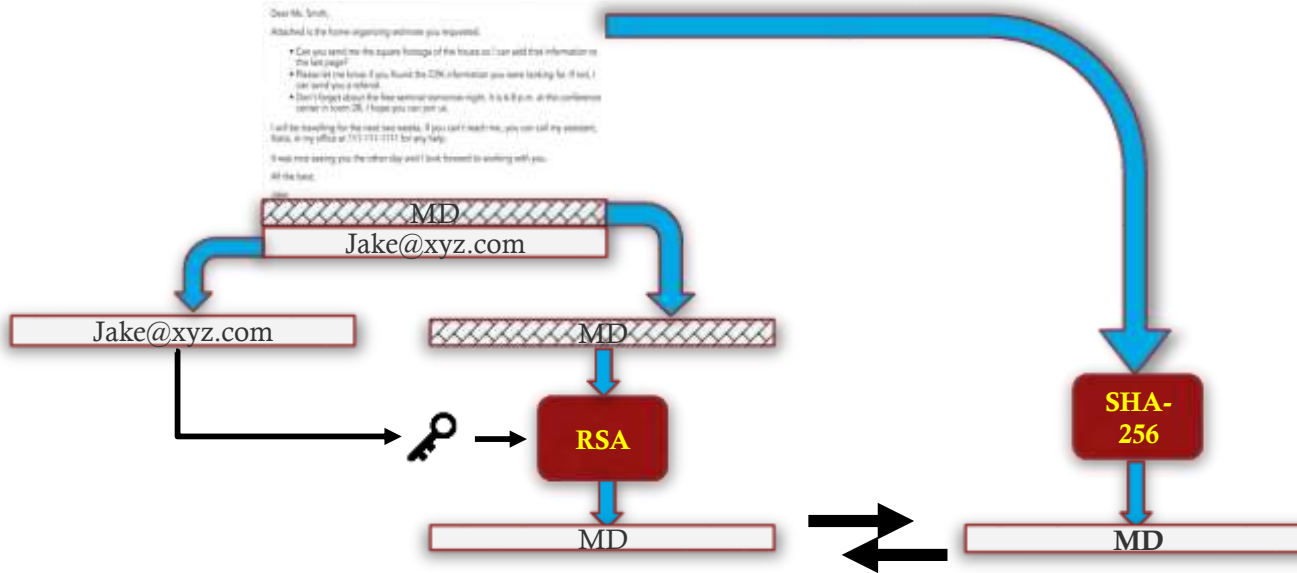
- Create a message
- Generate 256-bit message digest
 - SHA-256
- Encrypt the message digest
 - RSA using the sender's private key
- Append the result to the message
- Appended the identifying information for the signer
 - This will enable the receiver to retrieve the signer's public-key



AUTHENTICATION

- **Receiver :**

- Decrypt and recover the message digest
 - RSA with the sender's public key
- Generate a new message digest for the message
- Compares it with the decrypted hash code
 - if the two match, the message is accepted as authentic



CONFIDENTIALITY



- What service can be used for Confidentiality?
- Encrypting messages
 - Most commonly AES with a 128-bit key
 - with the cipher block chaining (CBC) mode
- Key (content-encryption key)
 - Encrypted
 - typically with RSA
 - the receiver's public key
 - Used only once

Dear Mr. Smith,

Attached is the home organizing estimate you requested.

- Can you send me the square footage of the house so I can add that information to the last page?
- Please let me know if you found the CDK information you were looking for. If not, I can send you a referral.
- Don't forget about the free annual home visit right. It is a \$89.00 at the conference center in room 20. I hope you can join us.

I will be traveling for the next two weeks. If you can't reach me, you can call my assistant, Katie, at my office at 711-111-1111 for any help.

It was nice seeing you the other day and I look forward to working with you.

All the best,

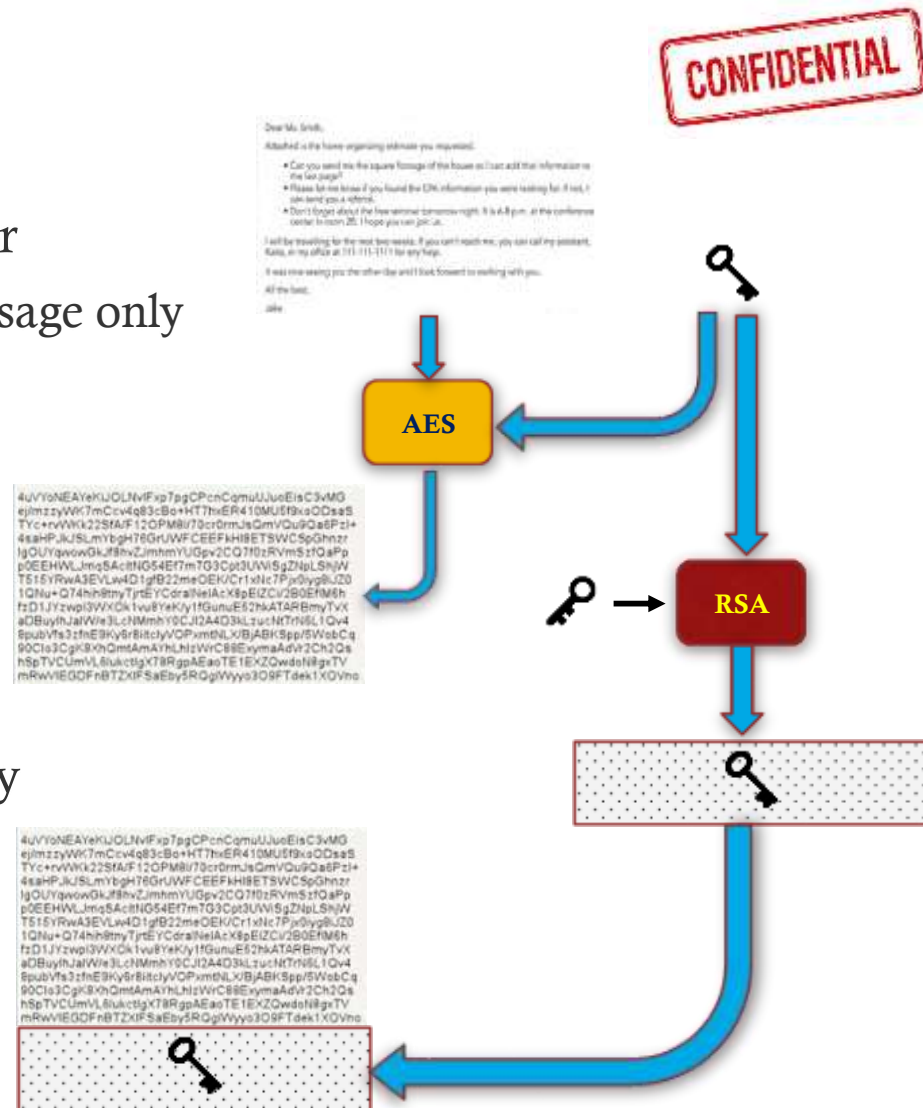
Jill

4uVVoNEAYeKJULNvFxp7pgCPcnCgmsUJueEIsCSvM0
ejImzzyWk7mCcv4q83cBo*HT7hwER410MU5BvaQDsas
TYc+rvWk22SIA/F12OPM8U73ccr0rmJaQmVQu9Qs6Pzi+
4saHPJkUSLmYbqH78GrUWFCEEFKH8ETSVVCSpGhnzr
lgOUYqvwGkJf8hvZjmhmYUGpv2CQ7f0zRVmSztQaPp
p0EEHWLJmsSAc8H054E7m7G3Cpt3UWISgZhlPLShjW
TS15YRwA3EVLw4D1gB22meDEK/Cr1xNc7Pjx0y98JZ0
1Qhu+Q74hnbmyTjEY/Cdr4hwaAcX8pEIZCv790EIM6h
tzD1Jyzwp3WXX0k1vubYkKy1HGunsE52haATARBmyTVx
aDBuyhJatVwa3LcNMmhYQCJ2A4D3kLzucNTnH5L1Qv4
8pubVfs3ztnE9Ky8BltcyVOPxmbILXBJABK5pp/5WobCq
90C1a3CgK8XhQmAmAYhLhztVVC88EymaAdv2Ch2Qs
hSpTVCUmV1,8ukctlgX78RgaAEaoTE1EXZQwdaI8gxTV
mRwVIEQDFnBTZkXfSaEbySRGgWvys3Q8FTdek1XOVhs

CONFIDENTIALITY

- **Sender**

- Generates a message
- Generate a random 128-bit number
 - content-encryption key for this message only
- Encrypt the message
 - AES
 - using the content-encryption key
- Encrypt the content-encryption key
 - RSA
 - using the recipient's public key
- Attached it to the message



CONFIDENTIALITY

CONFIDENTIAL

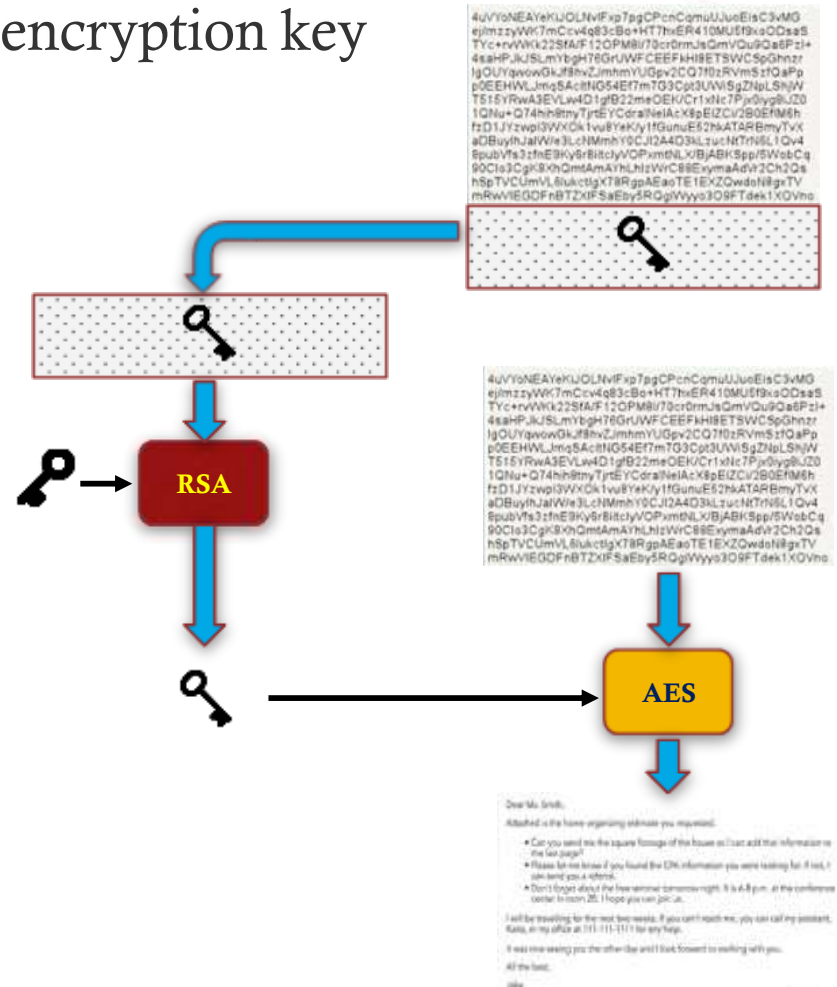
- Receiver

- Decrypt and recover the content-encryption key

- RSA
- its private key

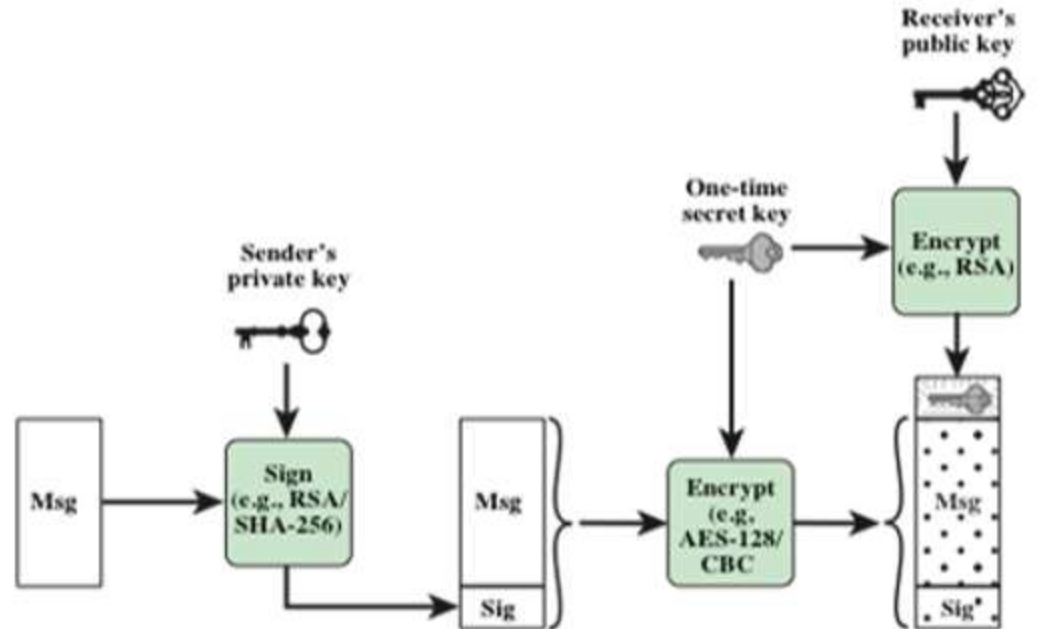
- Decrypt the message

- AES
- The content-encryption key

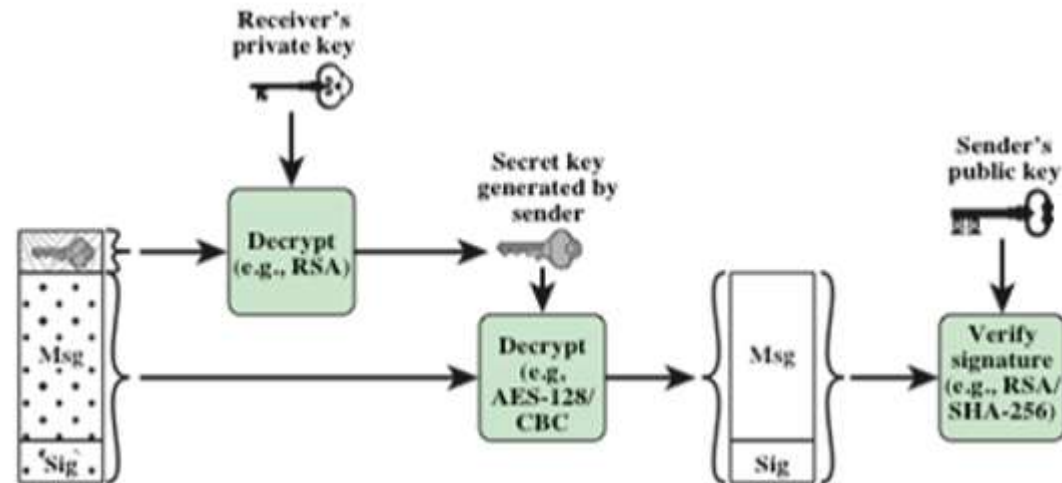


Simplified S/MIME Functional Flow

- Sender signs, then encrypts message



- Receiver decrypts message, then verifies sender's signature



S/MIME MESSAGE CONTENT TYPES

S/MIME uses the following message content types Cryptographic Message Syntax

Data

- Refers to the inner MIME-encoded message content, which may then be encapsulated in a SignedData, EnvelopedData, or CompressedData content type

SignedData

- Used to apply a digital signature to a message

EnvelopedData

- This consists of encrypted content of any type and encrypted-content encryption keys for one or more recipients

CompressedData

- Used to apply data compression to a message

Cryptographic Algorithms used in S/MIME

Function	Requirement
Create a message digest to be used in forming a digital signature.	MUST support SHA-256 SHOULD support SHA-1 Receiver SHOULD support MD5 for backward compatibility
Use message digest to form a digital signature.	MUST support RSA with SHA-256 SHOULD support – DSA with SHA-256 – RSASSA-PSS with SHA-256 – RSA with SHA-1 – DSA with SHA-1 – RSA with MD5
Encrypt session key for transmission with a message.	MUST support RSA encryption SHOULD support – RSAES-OAEP – Diffie–Hellman ephemeral-static mode
Encrypt message for transmission with a one-time session key.	MUST support AES-128 with CBC SHOULD support – AES-192 CBC and AES-256 CBC – Triple DES CBC

S/MIME CONTENT TYPES – enveloped Data

- The steps for preparing an envelopedData MIME entity are:
 - Generate a pseudorandom session key for a particular symmetric encryption algorithm (RC2/40 or triple DES)
 - For each recipient, encrypt the session key with the recipient's public RSA key
 - For each recipient, prepare a block known as *RecipientInfo* that contains an identifier of the recipient's public-key certificate
 - Encrypt the message content with the session key

S/MIME CONTENT TYPES – signedData

The steps for preparing a signedData MIME entity are as follows:

Select a message digest algorithm (SHA or MD5)

Compute the message digest (hash function) of the content to be signed

Encrypt the message digest with the signer's private key

Prepare a block known as *SignerInfo* that contains the signer's public-key certificate, an identifier of the message digest algorithm, an identifier of the algorithm used to encrypt the message digest, and the encrypted message digest

S/MIME CERTIFICATE PROCESSING

- A S/MIME user has several key management functions to perform:
 - **Key generation**
 - The user or some related administrative utility **MUST** be capable of generating separate Diffie-Hellman and DSS key pairs and **SHOULD** be capable of generating RSA key pairs
 - Each key pair **MUST** be generated from a good source of nondeterministic random input and be protected in a secure fashion
 - A user agent **SHOULD** generate RSA key pairs with a length in the range of 768 to 1024 bits and **MUST NOT** generate a length of less than 512 bits
 - **Registration**
 - A user's public key must be registered with a certification authority in order to receive an X.509 public-key certificate
 - **Certificate storage and retrieval**
 - A user requires access to a local list of certificates in order to verify incoming signatures and to encrypt outgoing messages
 - Such a list could be maintained by the user or by some local administrative entity on behalf of a number of users

More Updates

Any QUESTIONS?

